

Aiyracare — Dossiê para Análise Jurídica

Documento: Dossiê descritivo de produto, dados e conformidade

Versão: 1.0

Data: 15 de setembro de 2026

Destinatário: Assessoria jurídica (análise humana)

Idioma: Português (Brasil)

Aviso importante

Este documento descreve o **estado técnico e funcional** da plataforma Aiyracare com base na documentação interna do repositório `aiyra-care` e nos modelos legais em `docs/legal/`. **Não constitui parecer jurídico.** Os textos de Termos de Uso, Política de Privacidade e demais políticas versionadas em `docs/legal/*/v1.0.md` são **modelos operacionais** pendentes de revisão formal antes de go-live público e cobrança ampla.

Sumário

- [1. Identificação e propósito](#)
- [2. Público-alvo e modelo de negócio](#)
- [3. O que o produto é e o que não é](#)
- [4. Arquitetura e infraestrutura de dados](#)
- [5. Funcionalidades por domínio](#)
- [6. Tratamento de dados pessoais \(LGPD\)](#)
- [7. Menores de idade e consentimento](#)
- [8. Integrações com portais de saúde \(scraping e APIs\)](#)
- [9. Compartilhamento clínico e acesso do médico](#)
- [10. Inteligência artificial, OCR e assistente Ava](#)
- [11. Cobrança, assinaturas e pagamentos](#)
- [12. Acesso familiar e controle de permissões](#)
- [13. Suporte ao usuário e observabilidade](#)
- [14. Horizonte B2B \(profissionais e parceiros\)](#)
- [15. Programa de indicação \(em debate\)](#)
- [16. Segurança da informação](#)
- [17. Documentos legais existentes no repositório](#)
- [18. Enquadramento regulatório resumido](#)
- [19. Incidentes e direitos do titular](#)
- [20. Status de implementação](#)

21. [Questões abertas para o advogado](#)

22. [Referências internas](#)

1. Identificação e propósito

1.1 Nome e natureza

AiyraCare é uma plataforma digital **B2C (família/cuidador)** para **organizar, centralizar e compartilhar** informações de saúde de membros da família — com foco inicial em cuidado pediátrico, mas suportando adultos na mesma conta.

1.2 Missão declarada

Permitir que responsáveis legais e cuidadores:

- Importem e mantenham atualizado o histórico de saúde (consultas, exames, vacinas, medicações, documentos, planos de saúde).
- Registrem eventos do dia a dia com baixo esforço.
- Preparem material estruturado para consultas médicas.
- Compartilhem resumos com profissionais de saúde de forma controlada.

1.3 Posicionamento regulatório pretendido (MVP)

- **Organizador familiar** de histórico de saúde.
- **Não** prontuário eletrônico oficial de instituição de saúde.
- **Não** prestador de serviços médicos, diagnóstico ou emergência.
- Resumos clínicos **determinísticos** (gerados a partir de dados já cadastrados, sem “inventar” informação clínica via IA no export principal).

Referência interna: `docs/legal/ANVISA_SAMD_POSITION.md` , `docs/legal/terms-of-use/v1.0.md` §2.

2. Público-alvo e modelo de negócio

2.1 Personas principais

Persona	Descrição	Relação com dados
Cuidador / responsável legal	Pai, mãe ou guardião que cria conta e gerencia perfis	Titular da conta; controlador indireto dos dados dos pacientes vinculados
Paciente (perfil de saúde)	Criança ou adulto cujo histórico é gerido	Titular dos dados de saúde; menor depende do responsável
Cuidador convidado	Familiar com acesso parcial via convite	Operador autorizado pelo titular da conta
Médico (consumidor externo)	Profissional que recebe link/e-mail de export	Sem conta obrigatória no MVP; acesso via link temporário
Parceiro B2B (horizonte)	Clínica, laboratório, operadora	Bounded context separado; primitives de organização já existem

2.2 Modelo comercial

Camada	Descrição
Freemium	Funcionalidades base com franquia gratuita (ex.: uso de LLM/OCR limitado)
Assinatura família	Plano recorrente via Stripe
Pacotes de créditos	Compra avulsa para funcionalidades de consumo (ex.: interpretação de manuscrito)
B2B (futuro)	Planos profissionais para médicos/clínicas — não lançado

Processamento de pagamento: **Stripe** (identificador de cliente; não armazena PAN de cartão na plataforma).

3. O que o produto é e o que não é

3.1 O produto é

- Repositório pessoal/familiar de dados de saúde consolidados de múltiplas fontes.
- Ferramenta de preparação para consulta (export PDF, link temporário, QR Code, e-mail ao médico).
- Integrador com portais de operadoras e laboratórios **mediante credenciais fornecidas pelo usuário**.
- Assistente conversacional (Ava) com guardrails e quotas — **apoio organizacional**, não substituto de consulta médica.
- Plataforma com gate de compliance (aceite de termos e políticas versionados).

3.2 O produto não é

- Prontuário eletrônico certificado (SBIS/CFM) de estabelecimento de saúde.
- Sistema de diagnóstico, prescrição ou triagem de emergência autônoma.
- Substituto de pediatra, médico ou farmacêutico.
- Fonte oficial de verdade clínica perante operadoras ou SUS.
- Marketplace de dados de saúde (não há venda de dados pessoais).

3.3 Disclaimers recorrentes na UI

- Export clínico e portal do médico: *“Documento gerado automaticamente a partir dos registros do cuidador. Não substitui prontuário oficial.”*
- Ava e OCR: usuário deve revisar antes de decisões de saúde.
- Urgência: orientação a SAMU (192) e serviços de emergência.

4. Arquitetura e infraestrutura de dados

4.1 Stack técnica (resumo)

Componente	Tecnologia	Função
API backend	Node.js 22, Fastify, TypeScript	Lógica de negócio, integrações
Frontend web	React 19, Vite	Interface do cuidador
Banco relacional	PostgreSQL (Supabase)	Dados estruturados, entitlements, compliance
Autenticação	Supabase Auth	Login e identidade (<code>auth_subject</code>)
Arquivos	Google Cloud Storage (GCS)	Documentos, imagens, laudos
Grafo (opcional)	Neo4j	Associações clínicas (não substitui Postgres)
Pagamentos	Stripe	Checkout, assinatura, webhook
E-mail transacional	Resend	Convites família, e-mail ao médico (export)
LLM / OCR	Groq, OpenAI, Google Vision (sob demanda)	Ava, OCR, manuscrito

4.2 Princípio arquitetural

Arquitetura **hexagonal** no backend: domínio → aplicação → infraestrutura. Separação entre:

- **Dados canônicos** (Postgres): entidades, atributos, credenciais criptografadas.
- **Associações** (Neo4j, opcional): vínculos entre entidades para visualização de encadeamento clínico.

4.3 Ambientes

- Desenvolvimento local e preview local documentados.
- Produção/preview em GCP planejados com segregação de ambientes.
- Variáveis sensíveis: `CRYPTO_KEY` (AES-256-GCM), chaves Supabase, Stripe, Resend.

4.4 Retenção geral

Tipo	Política típica
Conta e pacientes	Enquanto conta ativa + obrigações legais
Links de export (<code>clinical_export_shares</code>)	TTL configurável (ex.: 48h na UI; até 7 dias na API)
Relatórios de suporte	30 dias (<code>expires_at</code>)
Acesso ao perfil em suporte (opt-in)	7 dias
Aceites legais	Prazo legal aplicável (prova de consentimento)

5. Funcionalidades por domínio

5.1 Conta, onboarding e compliance

Funcionalidade	Descrição jurídica relevante
Cadastro/login	E-mail + autenticação Supabase
Onboarding	Perfil titular, cadastro de pacientes
Compliance gate	Bloqueio de uso até aceite de Termos e Privacidade vigentes
Aceite versionado	Registro em PG: versão, hash SHA-256 do texto, IP, user-agent
Exclusão de conta	<code>DELETE /auth/account</code> — direito de eliminação
Documentos legais públicos	<code>/termos</code> , <code>/privacidade</code> , <code>/cookies</code> , <code>/consentimento-menor</code>

API: `GET/POST /compliance/*`

5.2 Perfis de paciente e prontuário familiar

Dados por paciente (exemplos):

- Identificação: nome, data de nascimento, CPF, CNS, sexo, tipo sanguíneo.
- Clínico: alergias, medicações, vacinas, diagnósticos, medidas/crescimento.
- Utilização: consultas, autorizações de plano, exames, documentos.
- Timeline unificada de eventos.

Base legal típica: consentimento do responsável (menor) / execução de contrato / tutela da saúde no âmbito familiar.

5.3 Integrações e sincronização (Connect)

Portais suportados (varia por maturidade):

Portal	Método	Dados importados
Unimed BH	Login automatizado + APIs/scraping	Plano, extrato, autorizações, carteirinha
Amil	JWT/sessão + APIs	Plano, guias/tokens → autorizações
Mater Dei	Sessão JSON	Exames, visitas, laudos
Hermes Pardini / Grupo Fleury	OAuth PKCE	Exames
ConecteSUS / gov.br	FHIR guiado	Vacinas, exames SUS
Bradesco Saúde	Vínculo manual	Import limitado

O usuário **fornece credenciais** do portal; armazenadas criptografadas (AES-256-GCM). Sync pode ser manual ou agendado.

Ponto jurídico: autorização expressa nos Termos para uso das credenciais apenas para importação em nome do usuário; risco contratual com termos dos portais de terceiros.

5.4 Documentos, upload e OCR

- Upload de arquivos (receitas, laudos, certidões, exames).
- Pipeline OCR em cascata (Tesseract local → provedores cloud sob demanda).
- Interpretação de **manuscrito** consome créditos do usuário.
- Revisão humana na UI antes de persistir dados extraídos.

5.5 Agenda e lembretes

- Eventos agendados (`scheduled_events`).
- Sincronização opcional Google Calendar / Outlook OAuth.
- Lembretes de medicação (`CareReminderBanner`).
- Export ICS.

5.6 Acompanhamentos clínicos (health threads)

- Trilhas de investigação/acompanhamento com entradas cronológicas.
- Wizard de criação; vinculação a entidades clínicas.

5.7 Ava — assistente conversacional

- Chat global em todas as telas (dock).

- Lente de paciente (contexto limitado ao perfil selecionado).
- Guardrails contra temas off-topic.
- Quotas de tokens LLM por conta; franquia gratuita + pacotes.
- **Não** deve diagnosticar ou prescrever no MVP; citações a registros quando aplicável.
- Modo de teste em CI sem julgamento de qualidade clínica da LLM.

5.8 Dia a dia da família (épico `family-day-to-day`)

Entregas D1–D5:

ID	Funcionalidade	Descrição
D1	Wizard «Levar na consulta»	Link temporário, QR Code, PDF/impressão, WhatsApp
D2	«+ Registro rápido»	Captura em 5 tipos: nota, medida, medicação, agenda, documento
D3	Bloco «Hoje»	Timeline do dia na Carteira e dashboard
D4	E-mail ao médico + referral	Envio Resend; código de indicação <code>?ref=</code> no link (sem billing)
D5	Portal do médico	Página pública com UX para profissional, feedback útil, CTA

5.9 Export e compartilhamento clínico

Canal	Autenticação	TTL	Dados expostos
PDF / impressão	Conta do cuidador	—	Conforme modo escolhido
Link temporário	Público via token opaco	Configurável (48h UI)	Resumo ou completo
E-mail ao médico	Disparado pelo cuidador	Mesmo TTL do link	Link + template sem PHI no assunto além do nome
Portal médico (D5)	Público	Mesmo link	Cartão paciente + export + disclaimer

Modos:

- **summary:** alertas, meds, pendências, eventos recentes — recomendado para consulta.
- **full:** inclui exames, laudos, autorizações — maior exposição de PHI.

Tabela PG: `clinical_export_shares` — `token_hash`, `expires_at`, `created_by`, `referral_code`, `recipient_email`, `opened_at`.

5.10 Família — múltiplos cuidadores

- Convites por e-mail (`family-access/invites`).
- Círculos de cuidado (`care_circles`).
- Grants por paciente (`patient_access_grants`) com níveis de acesso.

- Compartilhamento de perfil entre famílias (`profile-shares`).
- Auditoria de ACL.

Não confundir com compartilhamento médico externo — ACL família é bounded context distinto.

5.11 Higienização de dados

- Detecção de duplicatas (exames, vacinas) estilo “Google Photos”.
- Resolução manual na UI; projeção opcional no Neo4j.

5.12 Emergência

- Página de emergência com orientações; **não** substitui SAMU.

5.13 Billing

- Franquia gratuita de uso LLM.
- Pacotes de créditos e assinatura família.
- Portal do cliente Stripe para gestão de assinatura.

6. Tratamento de dados pessoais (LGPD)

6.1 Controlador

Campo	Status
Razão social / CNPJ	A preencher antes do go-live (<code>LEGAL_ENTITY_NAME</code> , <code>LEGAL_CNPJ</code>)
Canal privacidade	<code>privacidade@aiyracare.com</code> (configurável via <code>LEGAL_PRIVACY_EMAIL</code>)
Canal suporte	Configurável via <code>LEGAL_SUPPORT_EMAIL</code>

6.2 Categorias de dados e bases legais (resumo)

Dado	Titular	Finalidade	Base legal (indicativa)	Suboperador
E-mail, auth, nome conta	Cuidador	Autenticação	Contrato	Supabase
Perfil paciente (incl. CPF, CNS)	Paciente / menor	Histórico clínico	Consentimento responsável / tutela saúde	Postgres, GCS
Dados clínicos	Paciente	Organização e export	Art. 11 LGPD	Postgres, GCS
Credenciais portal (criptografadas)	Cuidador	Sync	Consentimento no vínculo	Postgres
Aceites legais	Cuidador	Prova de consentimento	Obriga��o legal / contrato	Postgres
Pagamento (Stripe customer id)	Cuidador	Assinatura	Contrato	Stripe
OCR / LLM	Cuidador	Funcionalidade sob demanda	Contrato / consentimento	Groq, OpenAI, Google
Telemetria produto	Cuidador / an��nimo	Melhoria, m��tricas	Leg��timo interesse (sem PHI)	Postgres
Support reports	Cuidador	Suporte	Consentimento granular	Postgres
Export shares	Paciente	Compartilhar com m��dico	A��o do titular/respons��vel	Postgres

Fonte detalhada: docs/legal/DATA_PROCESSING_MAP.md

6.3 Transfer  ncia internacional

Suboperadores em cloud (Supabase, GCP, Stripe, LLMs) podem processar fora do Brasil. Medidas declaradas: contratos/DPA, criptografia em tr  nsito, minimiza  o de dados enviados a LLMs.

6.4 Minimiza  o e telemetria

Eventos de produto (product_events) usam allowlist de propriedades — proibido enviar texto cl  nico, OCR, mensagens de chat, credenciais. Eventos p  blicos do portal m  dico: clinician_share_viewed , clinician_share_feedback , clinician_share_cta_click — sem patientId no cliente.

6.5 Compartilhamento por a  o do titular

- Export PDF, link, e-mail, WhatsApp: iniciativa do cuidador.
- N  o h   venda ou licenciamento de base de dados a terceiros.

7. Menores de idade e consentimento

7.1 Fluxo

- Cadastro de paciente menor exige declaração de responsável legal.
- Documento `minor_guardian_consent` v1.0 versionado.
- Checkbox no cadastro + auditoria em PG.

7.2 Implicações

- Segundo guardião / custódia compartilhada: modelo de múltiplos cuidadores em evolução (`care_circles` , `grants`).
- Dados de crianças são **dados sensíveis** (art. 11 LGPD) — consentimento específico do responsável.

8. Integrações com portais de saúde

8.1 Mecanismo

1. Usuário vincula operadora/lab informando identificador (e-mail ou CPF) e senha do portal.
2. Credenciais criptografadas em `integration_links` .
3. Jobs de sync importam dados para entidades canônicas (`Authorization` , `Exam` , `MedicalRecord` , etc.).
4. Sync incremental reduz volume de dados transferidos.

8.2 Riscos jurídicos destacados internamente

Risco	Mitigação declarada
Violação de ToS do portal	Cláusula nos Termos: usuário autoriza e é responsável pelo uso conforme portal de origem
Armazenamento de credenciais	Criptografia AES-256-GCM; exclusão ao remover vínculo
Indisponibilidade do portal	Sem garantia de continuidade; sync best-effort

8.3 ConecteSUS / gov.br

- Login interativo gov.br para primeira importação.
 - Sessão persistida para reimport sem browser quando válida.
 - Dados públicos de saúde do titular no ecossistema SUS.
-

9. Compartilhamento clínico e acesso do médico

9.1 Fluxo «Levar na consulta»

- 1. Cuidador abre wizard no perfil do paciente.
- 2. Escolhe modo (resumo ou completo).
- 3. Sistema gera token opaco com TTL.
- 4. Canais: copiar link, QR, imprimir/PDF, WhatsApp, e-mail ao médico.

9.2 Link público e portal médico (D5)

- URL: `/clinical-export/:token` (opcional `?ref=CODIGO`).
- **Sem login** para o médico.
- Cabeçalho «Portal do médico», cartão do paciente, disclaimer, feedback de utilidade, CTA para landing.
- Abertura registra `opened_at` e telemetria `referral_link_opened` (servidor) / `clinician_share_viewed` (cliente).

9.3 Código de indicação (D4 — MVP)

- Cada conta pode ter `referral_code` (migration 066).
- Embutido na URL para **atribuição futura** de programa de indicação.
- **Não implementado:** billing, descontos, tabela `referrals` , termos do programa.

9.4 LGPD no compartilhamento

- Minimização: modo resumo por default na UX.
- TTL e revogação por expiração.
- Log de criação (`created_by`) e abertura (`opened_at`).
- Responsabilidade do cuidador na escolha do destinatário (e-mail do médico).

10. Inteligência artificial, OCR e assistente Ava

10.1 Usos de LLM

Feature	Finalidade	Quem paga tokens
Ava chat	Apoio organizacional, dúvidas	Cliente (franquia/pacotes)
OCR manuscrito	Transcrição sob demanda	Créditos do cliente
Classificação interna (rótulos operadora)	Otimização operacional	Orçamento interno (teto R\$100/mês) — não desconta cliente

10.2 Limites declarados (ANVISA / responsabilidade)

- Export clínico principal: **determinístico**, sem LLM gerando conteúdo clínico.
- Ava: disclaimers; sem diagnóstico/prescrição no MVP.
- Gate regulatório antes de agentes RAG clínicos (`legal-anvisa-review-rag`).
- Hard stops determinísticos (ex.: alergia × medicação) — regras sobre dados cadastrados, não triagem autônoma.

10.3 Dados enviados a provedores LLM

- Minimização: documento ou mensagem sob demanda do usuário.
 - Política interna de não usar Zen free com retenção de dados em produção (LGPD).
-

11. Cobrança, assinaturas e pagamentos

- Intermediador: **Stripe** (checkout, customer portal, webhooks).
 - Planos: franquia grátis, pacotes, assinatura família.
 - Cancelamento via portal Stripe ou suporte.
 - **Revisão jurídica pendente:** alinhamento CDC (cancelamento, reembolso) com política exibida no checkout.
-

12. Acesso familiar e controle de permissões

12.1 Modelo em três camadas

1. **Conta** (`app_account`) — login e billing.
2. **Círculo de cuidado** (`care_circle`) — grupo familiar.
3. **Perfil de saúde** (`patient`) — histórico clínico.

12.2 Mecanismos de acesso

- `patient_memberships` — vínculo conta↔paciente (guardian/self).
- `patient_access_grants` — permissões granulares.
- Convites por e-mail com token de aceite.
- Revogação e auditoria.

12.3 Casos sensíveis

- Mesmo paciente em dois círculos familiares (custódia compartilhada): grants independentes — em evolução.
-

13. Suporte ao usuário e observabilidade

13.1 Reportar problema

- Modal global com consentimento granular.
- Default: metadados técnicos sem PHI.
- Opt-in: acesso ao perfil por 7 dias para investigação.
- Retenção: 30 dias.

13.2 Ops interno

- Console ops separado (:3013) para métricas e alertas — **sem exposição a usuários finais**.
 - Telemetria de produto sem PHI para analytics de negócio.
-

14. Horizonte B2B

14.1 Primitives existentes

- Tabela `organizations` + `organization_members` (migration 055).
- API CRUD de organizações e membros (admin, clinician, read_only).

14.2 Planejado (não lançado)

- RBAC profissional completo.
- Console parceiro.
- Pacote clínico B2B, labs inbound, operadoras, farmácias.
- Marketplace farmácias (horizonte, com restrições ANVISA/propaganda).

Princípio: núcleo B2C família permanece; B2B adiciona personas sem transformar o produto em EMR hospitalar.

15. Programa de indicação (em debate)

15.1 Conceito

Loop bilateral paciente ↔ médico com descontos em planos — **documentado em discovery, não implementado** (exceto código `?ref=` para atribuição futura).

15.2 Riscos identificados internamente

Risco	Área
Inducement médico (CFM/ética)	Consultoria
Base legal para rastrear médico	LGPD
Desconto como subsídio	Fiscal
Auto-referral / fraude	Produto + ops

15.3 Dependências para go-live do programa

- Termos legais específicos.
- Tabela referrals / billing.
- Parecer fiscal e ética médica.

16. Segurança da informação

Medida	Implementação
Autenticação	Supabase Auth; Bearer em rotas protegidas
Autorização por paciente	patient_memberships + guards
Criptografia credenciais	AES-256-GCM (CRYPTO_KEY)
Links de export	Token opaco; hash SHA-256 no banco
HTTPS	Obrigatório em produção
Compliance gate	COMPLIANCE_GATE_ENABLED=1 em prod
Logs	Sanitização para evitar PHI em logs
Exclusão de conta	Endpoint dedicado

17. Documentos legais existentes

Documento	Versão	Caminho
Termos de Uso	1.0	docs/legal/terms-of-use/v1.0.md
Política de Privacidade	1.0	docs/legal/privacy-policy/v1.0.md
Política de Cookies	1.0	docs/legal/cookie-policy/v1.0.md
Consentimento responsável (menor)	1.0	docs/legal/minor-guardian-consent/v1.0.md
Mapa de tratamento LGPD	—	docs/legal/DATA_PROCESSING_MAP.md
Runbook incidentes	—	docs/legal/INCIDENT_RESPONSE.md
Checklist revisão advogado	—	docs/legal/LAWYER_REVIEW_CHECKLIST.md
Posicionamento ANVISA SaMD	—	docs/legal/ANVISA_SAMD_POSITION.md
Fiscal NFS-e	—	docs/legal/FISCAL_NFSE.md

Status: modelos operacionais — **revisão jurídica formal pendente** antes de go-live público e marketing B2C.

18. Enquadramento regulatório resumido

Área	Enquadramento interno	Ação recomendada
LGPD	Dados sensíveis de saúde + menores	Validar bases legais, DPA suboperadores, transferência internacional
ANVISA SaMD	Organizador familiar no MVP	Manter gate antes de IA clínica autônoma
CFM / PEP	Não é prontuário de clínica	Não prometer certificação SBIS
CDC	SaaS B2C com assinatura	Termos cancelamento/reembolso + Stripe
Fiscal	CNPJ + NFS-e via Contabilizei	Validar modelo de descontos se referral
Portais (scraping)	Risco contratual	Cláusula credenciais + responsabilidade usuário
Ética médica	Indicação bilateral (futuro)	Parecer antes de incentivos econômicos

19. Incidentes e direitos do titular

19.1 Direitos (art. 18 LGPD)

Direito	Canal	Implementação
Acesso / confirmação	privacidade@	Export clínico, contexto paciente
Correção	App	Edição perfil e paciente
Eliminação	privacidade@ + app	Excluir conta
Revogação consentimento	privacidade@	Remover integração, excluir conta
Informação compartilhamento	Política	/privacidade

19.2 Incidentes

Runbook em `docs/legal/INCIDENT_RESPONSE.md` :

- Classificação P1–P3.
- Contenção: revogar chaves, invalidar shares, preservar evidências.
- Notificação titulares e ANPD — **validar prazos e critérios com advogado** (art. 48 LGPD).

20. Status de implementação

20.1 Entregue (produto funcional em desenvolvimento/preview)

- Sync multi-portal, export clínico, share link, wizard consulta D1–D5.
- Família: convites, círculos, grants.
- Compliance tech: termos versionados, gate, aceites auditáveis.
- Billing Stripe, Ava, OCR, agenda, health threads.
- Suporte com consentimento granular.

20.2 Pendente / em debate

- Revisão jurídica formal dos textos v1.0.
- Go-live público (`COMPLIANCE_GATE_ENABLED` , Stripe live, CNPJ nos documentos).
- Programa de indicação com billing.
- RBAC profissional B2B.
- Conta médico autenticada.

20.3 Alterações recentes (set/2026) relevantes para jurídico

- **D4**: e-mail ao médico via Resend; `referral_code` em links de export; migration 066.
- **D5**: portal público do médico com feedback e telemetria anônima.

21. Questões abertas para o advogado

1. Os textos v1.0 (Termos, Privacidade, Cookies, Menor) são adequados para **B2C familiar** com dados sensíveis de saúde e menores (LGPD art. 11)?
2. As bases legais indicadas no mapa de tratamento são suficientes para cada fluxo (sync, OCR, Ava, export público)?
3. A cláusula de **credenciais de portais** nos Termos cobre adequadamente o risco de scraping/automação?
4. É necessário **DPA adicional** com Supabase, GCP, Stripe, Groq/OpenAI/Google?
5. As cláusulas de **transferência internacional** são suficientes?
6. O **export público sem login** (portal do médico) exige medidas adicionais (registro de acesso, termo para médico, limitação de modo full)?
7. O **código de indicação** em links (?ref=) e telemetria de abertura — qual base legal e necessidade de informação ao médico?
8. **Programa de indicação bilateral** (descontos) — riscos CFM, CDC, fiscal; viabilidade de modelo “enquanto ativo” vs vitalício.
9. Posicionamento **ANVISA SaMD** para Ava + OCR atuais — confirmação de que permanece fora de SaMD de alto risco.
10. **Cancelamento e reembolso** Stripe — conformidade CDC.
11. Canal `privacidade@` e prazos de resposta a titulares — procedimento operacional adequado?
12. **Support reports** com opt-in de acesso ao perfil — consentimento específico suficiente?

22. Referências internas

Documento	Caminho
Compliance e arquitetura legal	<code>docs/LEGAL_COMPLIANCE.md</code>
Mapa LGPD	<code>docs/legal/DATA_PROCESSING_MAP.md</code>
Checklist advogado	<code>docs/legal/LAWYER_REVIEW_CHECKLIST.md</code>
Modelo acesso familiar	<code>docs/FAMILY_ACCESS_MODEL.md</code>
Parceiros B2B	<code>docs/B2B_PARTNERS.md</code>
Discovery dia a dia + médico	<code>docs/discovery/day-to-day-clinician-access.md</code>
Discovery referral	<code>docs/discovery/referral-growth-loop.md</code>
Uso LLM / Ava	<code>docs/LLM_USAGE.md</code> , <code>docs/AVA_VISION.md</code>
Feature cards	<code>docs/features/index.json</code>
Histórico de decisões	<code>docs/HISTORICO.md</code>

Elaborado a partir do repositório AiyraCare — para dúvidas técnicas de implementação, solicitar acesso ao código ou à documentação viva em `docs/` .

Fim do dossiê.